CYPHER GROUP INC. · SIMULATED CASE STUDY

CGI-AWS-001 — Cloud Configuration Compliance Review

Cypher Group Inc. · Version 1.0 · 16 October 2026

> **Simulated case study.** Cypher Group Inc. and its suppliers are simulated, and no real cloud account was scanned: every configuration result below is a labelled scenario. The benchmark, the AWS Security Hub control IDs, the audit commands and the framework mappings are real. CIS recommendation titles are reproduced as published; obtain the benchmark from the Center for Internet Security.

Field	Value
Document ID	**CGI-AWS-001**
Version	1.0
Status	Draft for approval
Review date	16 October 2026 (simulated fieldwork 12-16 October 2026)
Prepared by	O.S — reviewer
Approving authority	Jerry Gold, Chief Executive Officer
Benchmark	**CIS Amazon Web Services Foundations Benchmark v5.0.0** — 63 recommendations, 5 sections
Cloud provider	CloudCo (CGI-VEN-001), modelled on AWS, so AWS service names are used throughout
Mapped to	ISO/IEC 27001:2022 Annex A · AICPA 2017 Trust Services Criteria (SOC 2) · NIST CSF 2.0 · CGI-RSK-001 risk IDs
Inputs consumed	CGI-POL-001 to -005 · CGI-RSK-001 v1.1 (14 risks) · CGI-GAP-001 v1.1 (1.32) · CGI-TPR-001 VRA-2026-001 (four CloudCo CUECs, conditions C1–C4) · CGI-ISO-001 (93-control SoA) · CGI-SOC-001 / CGI-IAU-001 (38 criteria, 37 findings)
Nature of the work	A compliance and configuration review against a published benchmark. Not cloud engineering.
Next review	Quarterly re-assessment, first due 30 June 2027 (AWS-17)

Headline result. Cypher passes **12 of the 60 CIS recommendations that apply to it (20.0%)**, and **24.4%** of the profile it must meet. Three of the 48 failures are open doors today, all left behind by temporary work that never ended:

- an administrator port (SSH) reachable from the whole internet;
- a former contractor's login with no MFA;
- a former consultant's cloud account that can still read a 2024 copy of the customer database.

None of CloudCo's four CUECs is performed. The controls the risk register credited against cloud misconfiguration turn out not to operate, so **R-005 rises from 12 (High) to 20 (Critical)** and the register moves to **v1.2** (residual total 122 → 130).

The decision:

- **NO-GO** on telling enterprise buyers the cloud follows the CIS benchmark.
- **GO** on a seven-day containment sprint, which needs no new spend and brings R-005 back to High by 30 November.

No maturity score moves. A review that finds a control absent measures the gap; it does not close it.

Contents

- Part 1 — The Why
- Part 2 — Scope, method and profile
- Part 3 — The CIS assessment
- Part 4 — The four CloudCo CUECs, closed out
- Part 5 — Five-way mapping

- Part 6 — Findings register
- Part 7 — R-005 recalculated: CGI-RSK-001 v1.2
- Part 8 — Remediation roadmap and reconciliation
- Part 9 — Effect on maturity, the SoA and SOC 2 readiness
- Part 10 — One-page executive summary
- Appendix A — Verification, assumptions and limitations
- Appendix B — Glossary

Files in this deliverable

File	What it holds
`07-aws-cloud-compliance.md` / `.pdf`	This report
`07-aws-cloud-compliance.xlsx`	17 sheets: the 63-row assessment, formula scorecard, CUECs, findings, five-way map, R-005 recalculation, register v1.2, roadmap, conflicts, maturity, issue checklist (22 checks, all PASS)
`07-aws-cloud-compliance.csv`	The 63-row assessment, one value per cell
`data/`	16 data sets — see data/README.md
`../templates/`	CIS assessment, multi-framework mapping and cloud findings register templates

Part 1 — The Why

1.1 Framework, standard, benchmark: three different jobs

Word	What it is	It says	Example	Kitchen picture
Framework	A structure for organising a security programme. Voluntary.	*"Have these capabilities."*	NIST CSF 2.0 (Project 03)	The cookbook's table of contents
Standard	Requirements you can be audited and certified against	*"You **shall** do this."*	ISO/IEC 27001 (Project 05)	The food-safety law the inspector enforces
Benchmark	A settings checklist for one technology	*"Set **this switch** to **this value**."*	CIS AWS Foundations Benchmark (this project)	The oven manual: 180 °C, door seal tight

The test: can you check it by looking at a setting? If yes, it is a benchmark item. If you need a person, a document or a meeting, it is a framework or standard requirement. ISO/IEC 27001 says configuration **shall** be managed (A.8.9); it never says which switch. **The benchmark is how an auditor turns that sentence into evidence.**

1.2 CIS, its levels, and the ladder

The **Center for Internet Security (CIS)** is a non-profit that publishes consensus-built configuration benchmarks. This review uses **v5.0.0** of the AWS Foundations Benchmark because it is the version **AWS Security Hub CSPM automates**. A review should run against the version its tooling can evidence; re-baselining to the newest release is on the roadmap (AWS-17).

```
BENCHMARK          CIS AWS Foundations v5.0.0        one document
  SECTION            3 Logging                       five of them
    SUB-SECTION        2.1 S3                        only in some
sections
      RECOMMENDATION     3.2 log file validation     63 of them: the
thing you test
        stickers on every recommendation (not rungs on the ladder):
          PROFILE              Level 1 or Level 2
          ASSESSMENT STATUS    Automated or Manual
```

- **Level 1** — the basics: practical, low cost, little impact on how things work.
- **Level 2** — defence in depth. Includes Level 1, and may cost money or convenience (hardware keys, extra logging).
- **Automated** — a tool can read the setting. **Manual** — a person has to look, read or judge.

1.3 Tool IDs are not CIS IDs

AWS Security Hub gives its checks its own IDs. **`IAM.9` is a tool control ID; `1.4` is the CIS recommendation it tests.** The two numbering systems drift apart between versions:

- `CloudTrail.2` tests CIS **3.5**, not 3.2;
- `EC2.1` tests public snapshots, not SSH;
- `CloudWatch.1` (the root-usage alarm) maps to nothing in the v5.0.0 standard.

That is why the assessment carries both columns. Only **37 of the 63 recommendations (58.7%) have a Security Hub control at all**, so a fully green Security Hub dashboard still leaves the rest of the benchmark unchecked.

1.4 The shared responsibility model

CloudCo secures **the building**: data centres, hardware, the hypervisor and the managed-service software. Cypher secures **what it puts inside and how it sets the dials**: its data, its identities, its settings. The line moves with the service type, but one rule never moves: **configuration and data are always the customer's.**

Service type	Example	CloudCo also runs	Cypher still owns
Infrastructure	EC2 virtual server	Hardware, hypervisor	Operating system, patching, firewall rules, IAM, data
Managed	RDS database	+ database engine and patching	Who can connect, encryption, public access, IAM, data
Abstracted	S3 storage	+ almost everything	Bucket policy, Block Public Access, encryption choice, IAM, data

This is why **R-005 sits on Cypher's side of the line**, why CloudCo's clean SOC 2 report cannot lower it, and why CloudCo's report lists four **complementary user entity controls (CUECs)**, controls it assumes Cypher performs. Project 04 found Cypher had accepted none of them. Part 4 tests them.

1.5 The services in one line each

Term	What it does	Brakes (preventive) or seatbelt (detective)?
IAM	Users, roles and policies: who may do what	Brakes
Root user	The account's first, all-powerful identity; policies cannot restrict it	—
MFA	A second proof at sign-in (app code or hardware key)	Brakes
CloudTrail	Records every API call: who, what, when, from where	Seatbelt
Log file validation	Signed digests proving the CloudTrail diary was not altered or pages removed	Seatbelt
AWS Config	Records every resource's settings over time and checks them against rules	Seatbelt
GuardDuty	Watches logs for threat patterns (stolen keys, crypto-mining)	Seatbelt
Security Hub CSPM	Collects findings and runs the automated CIS checks	Seatbelt
S3 Block Public Access	One account-wide switch that overrides any bucket made public by mistake	Brakes
KMS	Creates and controls encryption keys; every use is logged	Brakes (who can decrypt)

Term	What it does	Brakes (preventive) or seatbelt (detective)?
Security group / NACL	Firewall per server / per subnet	Brakes
VPC flow logs	Records which network connections happened	Seatbelt
SCP	An organisation rule even administrators cannot override	Brakes

1.6 Five ideas the assessment depends on

1. **Configuration drift.** A setting is right on Monday and wrong on Thursday because someone clicked in a hurry. A one-off check proves Monday; only continuous recording proves the weeks in between (the Type I versus Type II idea from Project 06).
2. **Infrastructure as code.** Settings written as reviewed, versioned code. The code *is* the configuration record and makes change control provable. Cypher does not use it yet (AWS-18).
3. **Automated versus manual.** A tool tests only what it can see. Manual checks cover the rest: "is root used for daily work?", "is the security contact current?".
4. **Compensating control.** An alternative that meets a requirement's intent when it cannot be met as written. It is acceptable only if documented, approved by the risk owner, at least as strong for the risk in question, and time-limited.
5. **Misconfiguration versus vulnerability.** A vulnerability is a flaw in code: it has a CVE, and the vendor patches it (R-004). A misconfiguration is a wrong setting chosen by the customer: there is no CVE, and every patch on earth leaves it open (R-005). That is why R-004 and R-005 have separate control gaps, CG-02 and CG-03.

1.7 How drawer 7 completes the programme

Projects 01 to 06 describe what Cypher *says*. Project 07 is the first look at what the cloud *actually does*.

Project	What it left open	What this review does with it
02	R-005 residual 12, held by CG-03 (no detective control)	Tests every credit behind the 12 and re-scores (Part 7)
03	REC-11 (CIS baseline) · PR.PS = 0, PR.IR = 0, DE.CM = 1	Says which Category moves, and why none does (Part 9)
04	Four CloudCo CUECs never accepted; conditions C1–C4	Names the checks that evidence each CUEC (Part 4)
05	A.8.9, A.8.20 and other cloud controls Not started	Supplies the configuration evidence an auditor would ask for
06	The mirror of CUECs; OFI-03, OFI-07; CC6 and CC7	Closes the CloudCo half of the mirror with evidence

Part 2 — Scope, method and profile

2.1 What was reviewed (simulated environment)

Element	What exists	Scope decision
Organisation	CloudCo organisation with 3 accounts: management (billing, created 2021), production (the platform), staging (pre-production)	In scope. Section 1, 3 and 4 checks run in all three; Section 2 and 5 resource checks run in production.
Regions	eu-central-1 (primary); us-east-1 (RDS snapshot copies); every other default region enabled but unused	In scope. Unused regions matter: an attacker launches resources where nobody looks.
Identity	IAM users per account: production has 9 (8 people with console passwords, 1 machine user codeco-deploy); 3 root users	In scope
Compute	Application on Amazon ECS with AWS Fargate behind an internet-facing load balancer (443 only); one EC2 bastion, cgi-prod-bastion-01	In scope
Database	One RDS for PostgreSQL instance, cgi-prod-db, Multi-AZ, private subnets; snapshots copied to us-east-1	In scope

Element	What exists	Scope decision
Storage	5 S3 buckets: cgi-prod-app-attachments (Restricted), cgi-prod-exports (Restricted), cgi-prod-cloudtrail-logs, cgi-www-assets (public website assets), cgi-data-migration-2024 (legacy)	In scope
Network	One production VPC (private and public subnets, default network ACL); a default VPC in every enabled region	In scope
Logging and monitoring	One single-region trail (production, eu-central-1, May 2023); Config and Security Hub enabled 05 Oct 2026 in production eu-central-1 and us-east-1; GuardDuty off	In scope
Staging resources	Workloads in the staging account	OUT OF SCOPE this cycle (limitation L-03). The CTO asserts staging holds no customer data; not verified.

2.2 How it was reviewed

Source	Used for	Strength
Security Hub CSPM, CIS v5.0.0 standard, production account (eu-central-1, us-east-1)	37 recommendations that have a Security Hub control	Automated, repeatable. Switched on 05 Oct 2026 for this review, so it proves the current state only
Read-only command line with a SecurityAudit role in all three accounts	The same checks in management and staging; recommendations CIS calls Automated that Security Hub does not test (1.12, 1.15, 1.17, 4.16, 5.1.2)	Direct reading of the setting
Manual inspection and inquiry of the CTO and IT Operations Manager	The 28 recommendations CIS marks Manual	Weakest evidence; labelled as such
CloudTrail history (eu-central-1 trail since May 2023)	Who made the changes behind each finding, and when	Covers one region of one account only (limitation L-02)

Every row in the assessment names its evidence and the exact command or console path a real reviewer would use, so the review can be re-performed.

2.3 Choosing the profile: Level 1, plus what Cypher has already promised

A company does not have to adopt every Level 2 recommendation, but **a policy or a contract can make one mandatory**. Six are:

CIS ID	Level	Why it is in the Cypher profile
1.5	Level 2	CGI-POL-002 s4.4.3 requires a hardware MFA device on the CloudCo root user
3.2	Level 2	CloudCo CUEC 1 requires CloudTrail log file validation
3.3	Level 2	TP-09 commits to AWS Config rules with alerting
3.5	Level 2	CloudCo CUEC 4 (encryption management for customer-controlled data)
3.6	Level 2	CloudCo CUEC 4 (key rotation is part of key management)
4.16	Level 2	REC-11 commits to continuous cloud security posture monitoring

The Cypher profile is therefore Level 1 (41) plus these 6 = 47 recommendations. The other 16 Level 2 recommendations are assessed and reported but not scored. **Policy and contracts outrank the profile choice:** CGI-POL-002 already demands hardware root MFA, and CloudCo's CUEC already demands log file validation, whatever CIS calls them.

2.4 Scoring method, published before any result

- **Score = PASS ÷ (recommendations in scope − N/A).** N/A is never counted as a pass.
- Three scores are reported: all 63, Level 1 only, and the Cypher profile. **The profile score is the one that matters.**
- **Baseline met** = profile score ≥ 90%.

- **Gate:** while any Critical or High finding is open, Cypher may not claim CIS alignment to a customer, whatever the percentage.
- **Severity** is set by the rule in Part 6.1, published before any finding was graded.

Part 3 — The CIS assessment

3.1 Scorecard

Measure	Result
Recommendations assessed	**63** — 12 PASS · 48 FAIL · 3 N/A
Score, all applicable recommendations	**20.0%** (12 of 60)
Score, Level 1	**27.5%** (11 of 40)
Score, Cypher profile	**24.4%** (11 of 45) — **baseline not met**
Score, automated recommendations	27.3% (9 of 33)
Score, manual recommendations	11.1% (3 of 27)
Recommendations Security Hub can test	37 of 63 (58.7%)
Findings	**15 — 3 Critical · 6 High · 4 Medium · 2 Low**
CloudCo CUECs performed	**0 of 4**
Claim CIS alignment to enterprise buyers?	**NO-GO** — three Critical findings open

3.2 By section

Section	Recommendations	PASS	FAIL	N/A	Score
1 Identity and Access Management	21	7	14	0	33.3%
2 Storage	9	3	5	1	37.5%
3 Logging	9	0	8	1	0.0%
4 Monitoring	16	0	16	0	0.0%
5 Networking	8	2	5	1	28.6%
Total	63	12	48	3	**20.0%**

What the shape says:

- **Logging (0%) and Monitoring (0%):** the detective layer does not exist. That is CG-03, now evidenced instead of assumed.
- **Identity (33%):** the strongest section, and its passes are the cheap ones. Root MFA exists; root use is not restricted.

3.3 The featured five

Five checks were chosen for deep review because each sits on the R-005 path. Four were first proposed with the wrong identifiers, which is the trap in 1.3, so the corrections are recorded:

As first proposed	Correct	Why
1.4 (IAM.9)	**1.4** (IAM.9)	Correct as given.
2.1.1 (S3.1)	**2.1.4** (S3.1 (account); S3.8 (bucket))	2.1.1 is 'deny HTTP requests' (S3.5). Block Public Access is 2.1.4, tested by S3.1 at account level and S3.8 per bucket.
3.2 (CloudTrail.2)	**3.2** (CloudTrail.4)	CloudTrail.2 tests encryption at rest, which is CIS 3.5. Log file validation is tested by CloudTrail.4.

As first proposed	Correct	Why
4.1 (CloudWatch.1)	**4.3** (no Security Hub control)	4.1 is 'unauthorised API calls'. Root usage is 4.3, and the v5.0.0 standard has no Security Hub control for it: it is a manual check. CloudWatch.1 maps only in the v1.2.0 and v1.4.0 standards.
5.1 (EC2.1)	**5.3** (EC2.53)	EC2.1 tests public EBS snapshots. SSH from 0.0.0.0/0 on a security group is 5.3, tested by EC2.53 (EC2.13 was the v1.2.0 control).

1.4 · Ensure MFA is enabled for the 'root' user account · PASS

Field	Value
CIS ID	1.4
Security Hub control ID	IAM.9
Platform asset and service	IAM - root user
CIS profile level	Level 1
Assessment method	Automated per CIS · evidenced by Security Hub CSPM (production) + read-only CLI (other accounts)
Configuration posture (scenario)	**PASS**
Technical observation and root cause	MFA is active on all three root users. All three devices are virtual (an authenticator app), which satisfies 1.4 but not CGI-POL-002 s4.4.3 or recommendation 1.5. A PASS here is one day's setting, not evidence that root use is restricted.
Mitigating policy reference (Drawer 1)	CGI-POL-002 s4.4.3
Core remediation directive	Keep, and upgrade to hardware MFA under 1.5.
Finding	-

2.1.4 · Ensure that S3 is configured with 'Block Public Access' enabled · FAIL

Field	Value
CIS ID	2.1.4
Security Hub control ID	S3.1 (account); S3.8 (bucket)
Platform asset and service	S3 - account-level Block Public Access; 5 buckets
CIS profile level	Level 1
Assessment method	Automated per CIS · evidenced by Security Hub CSPM (production) + read-only CLI (other accounts)
Configuration posture (scenario)	**FAIL**
Technical observation and root cause	Account-level Block Public Access is OFF (all four settings false) since 22 Feb 2024, when it was switched off to publish cgi-www-assets (website images and CSS). Bucket-level BPA is on for 3 buckets and off for cgi-www-assets (public by design) and cgi-data-migration-2024 (switched off 11 Jun 2024 to grant a consultant cross-account access, CF-03). No SCP stops anyone changing it.
Mitigating policy reference (Drawer 1)	CGI-POL-004 s4.2 Handling Matrix
Core remediation directive	Front cgi-www-assets with CloudFront and Origin Access Control, then turn on all four account-level settings and protect them with an SCP.
Finding	CF-04; CF-03

3.2 · Ensure CloudTrail log file validation is enabled · FAIL

Field	Value
CIS ID	3.2
Security Hub control ID	CloudTrail.4
Platform asset and service	CloudTrail - cgi-prod-trail
CIS profile level	Level 2 (in the Cypher profile: CloudCo CUEC 1 requires CloudTrail log file validation)

Field	Value
Assessment method	Automated per CIS · evidenced by Security Hub CSPM (production) + read-only CLI (other accounts)
Configuration posture (scenario)	**FAIL**
Technical observation and root cause	Log file validation is disabled, so nobody can prove the diary was not edited or pages removed. It is Level 2 in CIS but mandatory for Cypher because CloudCo CUEC 1 names it.
Mitigating policy reference (Drawer 1)	None - no cloud configuration standard exists (CG-03)
Core remediation directive	Enable validation on the organisation trail; test it once with validate-logs and keep the output as evidence.
Finding	CF-06

4.3 · Ensure usage of the 'root' account is monitored · FAIL

Field	Value
CIS ID	4.3
Security Hub control ID	- (manual in the v5.0.0 standard)
Platform asset and service	CloudWatch Logs metric filters, alarms and SNS; EventBridge
CIS profile level	Level 1
Assessment method	Manual per CIS · evidenced by manual inspection and inquiry
Configuration posture (scenario)	**FAIL**
Technical observation and root cause	No metric filter, EventBridge rule, alarm or subscriber exists for this event. CloudTrail is not delivered to CloudWatch Logs or any other log platform, so the event cannot be monitored at all. CGI-POL-002 s4.4.3 requires an alert on every root use; four root sign-ins in 90 days raised none.
Mitigating policy reference (Drawer 1)	CGI-POL-002 s4.4.3
Core remediation directive	Create an EventBridge rule (or metric filter and alarm) for this event, routed through SNS to the security channel in ChatCo and to the IT Operations Manager's email, handled under the alert runbook.
Finding	CF-07

5.3 · Ensure no security groups allow ingress from 0.0.0.0/0 to remote server administration ports · FAIL

Field	Value
CIS ID	5.3
Security Hub control ID	EC2.53
Platform asset and service	EC2 - sg-bastion on cgi-prod-bastion-01
CIS profile level	Level 1
Assessment method	Automated per CIS · evidenced by Security Hub CSPM (production) + read-only CLI (other accounts)
Configuration posture (scenario)	**FAIL**
Technical observation and root cause	sg-bastion allows TCP 22 from 0.0.0.0/0. CloudTrail shows ext-ops-contractor added the rule on 14 Mar 2025 during a database incident. There is no change ticket and the rule was never removed. The bastion has a public IP and its role can read customer exports.
Mitigating policy reference (Drawer 1)	CGI-POL-003 s4.1.5 (ticket for every access change)
Core remediation directive	Remove the 0.0.0.0/0 rule today; replace the bastion with Session Manager (no inbound ports).
Finding	CF-01

What the five teach together:

- The single **PASS (1.4)** is the least informative result in the review. It proves one setting on one day; it says nothing about root *use* (1.6 fails), the factor *type* (1.5 fails) or whether anyone would *notice* root use (4.3 fails).

- The **four FAILs share one root cause.** Nothing records a change, nothing alerts on one, and no baseline says what "correct" is.

3.4 All 63 recommendations

Key observation shown; the full narrative, evidence, command, policy reference and five-way mapping for every row are in `07-aws-cloud-compliance.csv` and on sheet `01_CIS_Assessment`.

CIS	Recommendation	Level	Status	Security Hub	Result	Key observation	Finding
1.1	Maintain current contact details	L1	Manual	-	**PASS**	Primary contact name, address, telephone and email are current in all three accounts and match the company register (verified with the CEO).	-
1.2	Ensure security contact information is registered	L1	Manual	Account.1	**FAIL**	No security alternate contact is registered in any account.	CF-14
1.3	Ensure no 'root' user account access key exists	L1	Automated	IAM.4	**PASS**	No root access key exists in any account.	-
1.4	Ensure MFA is enabled for the 'root' user account	L1	Automated	IAM.9	**PASS**	MFA is active on all three root users.	-
1.5	Ensure hardware MFA is enabled for the 'root' user account	L2	Manual	IAM.6	**FAIL**	No hardware MFA device is registered for any root user.	CF-08
1.6	Eliminate use of the 'root' user for administrative and daily tasks	L1	Manual	-	**FAIL**	The management-account root user signed in 4 times in the last 90 days to download invoices and update the payment card.	CF-08
1.7	Ensure IAM password policy requires minimum length of 14 or greater	L1	Automated	IAM.15	**FAIL**	Minimum length is 8 in all three accounts.	CF-11
1.8	Ensure IAM password policy prevents password reuse	L1	Automated	IAM.16	**FAIL**	Password reuse prevention is not set in any account.	CF-11
1.9	Ensure MFA is enabled for all IAM users that have a console password	L1	Automated	IAM.5	**FAIL**	7 of 8 console users have MFA.	CF-02; CF-09
1.10	Do not create access keys during initial setup for IAM users with a console password	L1	Manual	-	**FAIL**	ext-ops-contractor was given a console password and an access key on the same day (14 Mar 2025).	CF-02
1.11	Ensure credentials unused for 45 days or more are disabled	L1	Automated	IAM.22	**FAIL**	ext-ops-contractor last signed in on 02 Apr 2025, 562 days ago.	CF-02
1.12	Ensure there is only one active access key for any single IAM user	L1	Automated	-	**PASS**	No user holds two active keys.	-
1.13	Ensure access keys are rotated every 90 days or less	L1	Automated	IAM.3	**FAIL**	Two keys exceed 90 days: codeco-deploy (412 days, used daily by the CodeCo deployment pipeline) and ext-ops-contractor (581 days, never used).	CF-10; CF-02
1.14	Ensure IAM users receive permissions only through groups	L1	Automated	IAM.2	**FAIL**	Two users have policies attached directly: ext-ops-contractor (cgi-ops-fullaccess) and codeco-deploy (cgi-deploy).	CF-09
1.15	Ensure IAM policies that allow full ':' administrative privileges are not attached	L1	Automated	-	**FAIL**	cgi-ops-fullaccess allows Action '' *on Resource* ''.	CF-09

CIS	Recommendation	Level	Status	Security Hub	Result	Key observation	Finding
1.16	Ensure a support role has been created to manage incidents with AWS Support	L1	Automated	IAM.18	**FAIL**	No role or group has the AWSSupportAccess policy.	CF-14
1.17	Ensure IAM instance roles are used for AWS resource access from instances	L2	Automated	-	**PASS**	The bastion uses an instance profile and the ECS services use task roles.	-
1.18	Ensure that all expired SSL/TLS certificates stored in AWS IAM are removed	L1	Automated	IAM.26	**PASS**	No server certificates are stored in IAM.	-
1.19	Ensure that IAM External Access Analyzer is enabled for all regions	L1	Automated	IAM.28	**FAIL**	No analyzer exists in any account or region.	CF-03; CF-09
1.20	Ensure IAM users are managed centrally via identity federation or AWS Organizations for multi-account environments	L2	Manual	-	**FAIL**	Each account has its own IAM users.	CF-09
1.21	Ensure access to AWSCloudShellFullAccess is restricted	L1	Manual	IAM.27	**PASS**	The managed policy AWSCloudShellFullAccess is attached to no identity.	-
2.1.1	Ensure S3 Bucket Policy is set to deny HTTP requests	L2	Automated	S3.5	**FAIL**	No bucket policy denies requests where aws:SecureTransport is false.	CF-13
2.1.2	Ensure MFA Delete is enabled on S3 buckets	L2	Manual	S3.20	**FAIL**	Versioning is on for cgi-prod-exports and cgi-prod-app-attachments; MFA Delete is on for none.	CF-13
2.1.3	Ensure all data in Amazon S3 has been discovered, classified, and secured when necessary	L2	Manual	-	**FAIL**	No data discovery has ever run and no bucket carries a classification tag.	CF-03
2.1.4	Ensure that S3 is configured with 'Block Public Access' enabled	L1	Automated	S3.1 (account); S3.8 (bucket)	**FAIL**	Account-level Block Public Access is OFF (all four settings false) since 22 Feb 2024, when it was switched off to publish cgi-www-assets (website images and CSS).	CF-04; CF-03
2.2.1	Ensure that encryption-at-rest is enabled for RDS instances	L1	Automated	RDS.3	**PASS**	Storage is encrypted with the CloudCo-managed key aws/rds.	-
2.2.2	Ensure the Auto Minor Version Upgrade feature is enabled for RDS instances	L1	Automated	RDS.13	**FAIL**	Auto minor version upgrade is off.	CF-15
2.2.3	Ensure that RDS instances are not publicly accessible	L1	Automated	RDS.2	**PASS**	PubliclyAccessible is false and the instance sits in private subnets.	-
2.2.4	Ensure Multi-AZ deployments are used for enhanced availability in Amazon RDS	L1	Manual	RDS.5; RDS.15	**PASS**	Multi-AZ is enabled.	-
2.3.1	Ensure that encryption is enabled for EFS file systems	L1	Automated	EFS.1; EFS.8	N/A	No EFS file systems exist in any region.	-
3.1	Ensure CloudTrail is enabled in all regions	L1	Manual	CloudTrail.1	**FAIL**	One trail exists: cgi-prod-trail, created in May 2023, single-region (eu-central-1), production account only.	CF-06
3.2	Ensure CloudTrail log file validation is enabled	L2	Automated	CloudTrail.4	**FAIL**	Log file validation is disabled, so nobody can prove the diary was not edited or pages removed.	CF-06

CIS	Recommendation	Level	Status	Security Hub	Result	Key observation	Finding
3.3	Ensure AWS Config is enabled in all regions	L2	Automated	Config.1	**FAIL**	AWS Config was switched on 05 Oct 2026, at the reviewer's request, in production eu-central-1 and us-east-1 only, so that Security Hub could run.	CF-07
3.4	Ensure that server access logging is enabled on the CloudTrail S3 bucket	L1	Manual	CloudTrail.7	**FAIL**	Server access logging is off on the trail bucket, so reads and deletions of the logs themselves are not recorded.	CF-06
3.5	Ensure CloudTrail logs are encrypted at rest using KMS CMKs	L2	Automated	CloudTrail.2	**FAIL**	Trail logs use SSE-S3 only.	CF-05
3.6	Ensure rotation for customer-created symmetric CMKs is enabled	L2	Automated	KMS.4	N/A	Not applicable because no customer-managed key exists.	CF-05
3.7	Ensure VPC flow logging is enabled in all VPCs	L2	Automated	EC2.6	**FAIL**	No VPC has flow logs, including the production VPC that holds the bastion and the database.	CF-12
3.8	Ensure that object-level logging for write events is enabled for S3 buckets	L2	Automated	S3.22	**FAIL**	No S3 data events are recorded.	CF-06
3.9	Ensure that object-level logging for read events is enabled for S3 buckets	L2	Automated	S3.23	**FAIL**	No read events are recorded.	CF-06; CF-03
4.1	Ensure unauthorized API calls are monitored	L2	Manual	-	**FAIL**	No metric filter, EventBridge rule, alarm or subscriber exists for this event.	CF-07
4.2	Ensure management console sign-in without MFA is monitored	L1	Manual	-	**FAIL**	No metric filter, EventBridge rule, alarm or subscriber exists for this event.	CF-07
4.3	Ensure usage of the 'root' account is monitored	L1	Manual	-	**FAIL**	No metric filter, EventBridge rule, alarm or subscriber exists for this event.	CF-07
4.4	Ensure IAM policy changes are monitored	L1	Manual	-	**FAIL**	No metric filter, EventBridge rule, alarm or subscriber exists for this event.	CF-07
4.5	Ensure CloudTrail configuration changes are monitored	L1	Manual	-	**FAIL**	No metric filter, EventBridge rule, alarm or subscriber exists for this event.	CF-07
4.6	Ensure AWS Management Console authentication failures are monitored	L2	Manual	-	**FAIL**	No metric filter, EventBridge rule, alarm or subscriber exists for this event.	CF-07
4.7	Ensure disabling or scheduled deletion of customer created CMKs is monitored	L2	Manual	-	**FAIL**	No metric filter, EventBridge rule, alarm or subscriber exists for this event.	CF-07
4.8	Ensure S3 bucket policy changes are monitored	L1	Manual	-	**FAIL**	No metric filter, EventBridge rule, alarm or subscriber exists for this event.	CF-07
4.9	Ensure AWS Config configuration changes are monitored	L2	Manual	-	**FAIL**	No metric filter, EventBridge rule, alarm or subscriber exists for this event.	CF-07
4.10	Ensure security group changes are monitored	L2	Manual	-	**FAIL**	No metric filter, EventBridge rule, alarm or subscriber exists for this event.	CF-07

CIS	Recommendation	Level	Status	Security Hub	Result	Key observation	Finding
4.11	Ensure Network Access Control List (NACL) changes are monitored	L2	Manual	-	**FAIL**	No metric filter, EventBridge rule, alarm or subscriber exists for this event.	CF-07
4.12	Ensure changes to network gateways are monitored	L1	Manual	-	**FAIL**	No metric filter, EventBridge rule, alarm or subscriber exists for this event.	CF-07
4.13	Ensure route table changes are monitored	L1	Manual	-	**FAIL**	No metric filter, EventBridge rule, alarm or subscriber exists for this event.	CF-07
4.14	Ensure VPC changes are monitored	L1	Manual	-	**FAIL**	No metric filter, EventBridge rule, alarm or subscriber exists for this event.	CF-07
4.15	Ensure AWS Organizations changes are monitored	L1	Manual	-	**FAIL**	No metric filter, EventBridge rule, alarm or subscriber exists for this event.	CF-07
4.16	Ensure AWS Security Hub is enabled	L2	Automated	-	**FAIL**	Security Hub was switched on 05 Oct 2026 in production eu-central-1 and us-east-1, at the reviewer's request, with the CIS v5.0.0 standard.	CF-07
5.1.1	Ensure EBS volume encryption is enabled in all regions	L1	Automated	EC2.7	**FAIL**	EBS encryption by default is off in every region.	CF-05; CF-01
5.1.2	Ensure CIFS access is restricted to trusted networks to prevent unauthorized access	L1	Automated	-	**PASS**	No security group allows TCP 445.	-
5.2	Ensure no Network ACLs allow ingress from 0.0.0.0/0 to remote server administration ports	L1	Automated	EC2.21	**FAIL**	The production VPC uses the default network ACL, which allows all inbound traffic from 0.0.0.0/0, including ports 22 and 3389.	CF-01
5.3	Ensure no security groups allow ingress from 0.0.0.0/0 to remote server administration ports	L1	Automated	EC2.53	**FAIL**	sg-bastion allows TCP 22 from 0.0.0.0/0.	CF-01
5.4	Ensure no security groups allow ingress from ::/0 to remote server administration ports	L1	Automated	EC2.54	**PASS**	IPv6 is not enabled in the production VPC; no ::/0 rule exists.	-
5.5	Ensure the default security group of every VPC restricts all traffic	L2	Automated	EC2.2	**FAIL**	Default security groups in the production VPC and in every default VPC still allow all traffic between members and all outbound traffic.	CF-12
5.6	Ensure routing tables for VPC peering are 'least access'	L2	Manual	-	N/A	No VPC peering connection exists.	-
5.7	Ensure that the EC2 Metadata Service only allows IMDSv2	L1	Automated	EC2.8	**FAIL**	The bastion allows IMDSv1 (HttpTokens = optional).	CF-01

Part 4 — The four CloudCo CUECs, closed out

4.1 Each CUEC against the benchmark

CloudCo's SOC 2 report (VRA-2026-001, finding F-010) assumes Cypher performs four controls. A CUEC counts as met only when all of it is met.

CloudCo CUEC	What CloudCo assumes	CIS evidence	Results	Verdict	Why	Owner	Closes when
CUEC 1	Organisation-wide CloudTrail with log file validation	3.1; 3.2; 3.4; 3.8; 3.9	3.1 FAIL · 3.2 FAIL · 3.4 FAIL · 3.8 FAIL · 3.9 FAIL	**NOT PERFORMED**	One single-region trail in one of three accounts, validation off. The CUEC's two words, 'organisation-wide' and 'validation', are both absent.	IT Operations Manager	AWS-06 (30 Nov 2026)
CUEC 2	MFA on the root account and restricted root use	1.3; 1.4; 1.5; 1.6; 4.3	1.3 PASS · 1.4 PASS · 1.5 FAIL · 1.6 FAIL · 4.3 FAIL	**NOT PERFORMED**	Partly performed, which counts as not performed. MFA exists, so half the CUEC is met. Restricted use is not: four undocumented root sign-ins in 90 days, no alert. A CUEC is met only when all of it is met.	Chief Technology Officer	AWS-07 (30 Nov 2026)
CUEC 3	Least-privilege IAM with periodic review	1.9-1.15; 1.19; 1.20	1.12 PASS · 1.9 / 1.10 / 1.11 / 1.13 / 1.14 / 1.15 / 1.19 / 1.20 FAIL	**NOT PERFORMED**	Full administrator (':') for every engineer and a forgotten contractor. 'Periodic review' is manual: zero privileged access reviews have ever been performed (OFI-15).	IT Operations Manager	AWS-12 (31 Jan 2027) + REC-02
CUEC 4	Encryption management for customer-controlled data	2.2.1; 3.5; 3.6; 5.1.1; 2.1.1	2.2.1 PASS · 3.5 FAIL · 3.6 N/A · 5.1.1 FAIL · 2.1.1 FAIL	**NOT PERFORMED**	Data is encrypted, but only with CloudCo-managed keys. 'Management' means Cypher controls who can decrypt; no customer-managed key exists, so nothing is managed.	Chief Technology Officer	AWS-11 (31 Dec 2026)

Result: 0 of 4 performed. Project 06 called them *unaccepted*; they are now evidenced as *not performed*. Those are different statements:

- **Unaccepted** means nobody has signed for them.
- **Not performed** means nobody does them.

4.2 Conditions C1 to C4 of CloudCo's conditional pass

The Project 07 brief asks which conditions this review closes. **None.** The conditions are not the CUECs, so a configuration review can only *support* C1.

Condition	Requirement	Due	Effect of this review	Reason	Roadmap
C1	Formally accept the four CUECs, assign each an owner, and record the acceptance against CGI-VEN-001	15 Dec 2026	SUPPORTS - does not close	C1 is a signature and four names, not a configuration. This review gives each owner the evidence to accept knowingly. Acceptance means taking responsibility, not claiming the controls already run. C1 can be closed on paper this month, with the AWS roadmap dates attached.	AWS-09
C2	Subscribe to the sub-processor change feed and perform a first reconciliation	15 Dec 2026	OUT OF REACH	A contract and monitoring action; no cloud setting evidences it.	-
C3	Purchase a support tier with a named escalation route, or record a CEO-approved acceptance	15 Dec 2026	OUT OF REACH	A commercial decision. Related but separate: CF-14 creates the support role that a support plan would use.	-
C4	Declare RTO and RPO and evidence one restore test (this is REC-03)	15 Dec 2026	OUT OF REACH	A backup test. Multi-AZ (2.2.4 PASS) is availability, not recoverability, and is not counted.	-

C1 is still closable by 15 December 2026. It asks for acceptance and owners, not for operating controls. AWS-09 puts the acceptance in front of the CEO with this review's evidence and the roadmap dates attached. If C1 is missed, CloudCo's conditional pass lapses to Fail.

4.3 The mirror in CGI-SOC-001

Project 06 paired four of Cypher's own customer CUECs with CloudCo's four. The CloudCo half now reads:

Cypher CUEC (to customers)	CloudCo CUEC (to Cypher)	Was (CGI-SOC-001)	Now (CGI-AWS-001)
CUEC-05 review the tenant audit log and report anomalies	CUEC 1 organisation-wide CloudTrail with validation	Unverified	**Not performed** — one single-region trail, validation off (CF-06)
CUEC-02 enable MFA, phishing-resistant for administrators	CUEC 2 MFA on root, restricted root use	Unaccepted	**Not performed** — MFA yes, restricted use no (CF-08)
CUEC-03 review your users' access at least quarterly	CUEC 3 least-privilege IAM with periodic review	Never performed	**Not performed** — *:* for every engineer, zero reviews (CF-09)
CUEC-07 classify the data you upload	CUEC 4 encryption management	No standard	**Not performed** — no customer-managed key exists (CF-05)

> **Cypher asks its customers to use phishing-resistant MFA for administrators. Its own administrators use authenticator-app codes.**

Part 5 — Five-way mapping

Every finding traced through five systems: **CIS → ISO/IEC 27001:2022 Annex A → SOC 2 Trust Services Criteria → NIST CSF 2.0 → CGI-RSK-001**. The per-recommendation mapping for all 63 rows is in the CSV.

Finding	CIS	ISO/IEC 27001 Annex A	SOC 2	NIST CSF 2.0	Risk
CF-01	5.3; 5.2; 5.7; 5.1.1	A.8.20; A.8.21; A.8.32; A.8.9	CC6.6; CC8.1	PR.IR-01; PR.PS-01	R-005; R-002
CF-02	1.9; 1.10; 1.11; 1.13; 1.14	A.5.18; A.8.2; A.8.5; A.5.17	CC6.2; CC6.3; CC6.1	PR.AA-01; PR.AA-05	R-005; R-003; VR-008
CF-03	2.1.4; 2.1.3; 1.19; 3.8; 3.9	A.5.9; A.5.12; A.8.3; A.8.10; A.5.20	C1.1; CC6.1; CC6.3	ID.AM-07; PR.DS-01; PR.AA-05	R-005; VR-001; VR-004
CF-04	2.1.4	A.8.3; A.5.15; A.8.9	CC6.1; CC6.6	PR.DS-01; PR.PS-01	R-005
CF-05	3.5; 3.6; 5.1.1	A.8.24	CC6.1	PR.DS-01	R-005; VR-004
CF-06	3.1; 3.2; 3.4; 3.8; 3.9	A.8.15; A.5.28	CC7.2	PR.PS-04; DE.CM-09	R-005; R-003
CF-07	4.1-4.15; 4.16; 3.3	A.8.16; A.8.9	CC7.1; CC7.2; CC7.3; CC8.1	DE.CM-01; DE.CM-03; DE.CM-09; DE.AE-02	R-005; R-003; R-001
CF-08	1.5; 1.6; 4.3	A.8.2; A.8.5	CC6.1; CC6.3	PR.AA-03; PR.AA-05	R-005
CF-09	1.15; 1.14; 1.20; 1.19	A.8.2; A.5.15; A.5.16; A.5.18; A.8.5	CC6.1; CC6.2; CC6.3	PR.AA-01; PR.AA-03; PR.AA-05	R-005; R-003; R-001
CF-10	1.13	A.5.17	CC6.1	PR.AA-01	R-005; R-004
CF-11	1.7; 1.8	A.5.17; A.8.5	CC6.1	PR.AA-03	R-001; R-005
CF-12	3.7; 5.5	A.8.15; A.8.16; A.8.20; A.8.22	CC6.6; CC7.2	DE.CM-01; PR.IR-01	R-005; R-002
CF-13	2.1.1; 2.1.2	A.8.24; A.5.14; A.8.13	CC6.7; CC6.1	PR.DS-02; PR.DS-11	R-005; R-002
CF-14	1.2; 1.16	A.5.24; A.5.5; A.8.2	CC2.3; CC7.4	RS.CO-02; RS.MA-01	R-005; R-002
CF-15	2.2.2	A.8.8	CC7.1	PR.PS-02	R-004; R-002

Patterns worth noticing:

- **CC6.1 is the most-mapped criterion (9 of 15 findings), and A.8.2 and A.8.5 lead the Annex A column (4 each).** Access and authentication are where the frameworks converge, and where Cypher is weakest.
- **CC8.1 (change management), the weakest criterion in Project 06, appears twice.** Both times it is a change nobody approved: the SSH rule and the alert gap that hid it.
- **R-005 appears in 14 of 15 findings.** CF-15 is the exception: it sits on the patching path (R-004, R-002), not the misconfiguration path. The review was scoped to R-005's controls, and the mapping shows it stayed scoped.

Part 6 — Findings register

6.1 Severity rule, published before grading

Severity	Rule
Critical	An exposure that exists now, reachable from outside Cypher (the internet or a third party), on a path to production or Restricted data, with no compensating control.
High	A missing guardrail or detective control on the R-005 path, or a failed CloudCo CUEC: one mistake away from Critical.
Medium	A Level 1 gap that weakens another control, or a policy breach with a compensating factor.
Low	A Level 2 defence-in-depth gap.

6.2 Register

ID	Severity	Finding	CIS	Owner	Due	Effort	Roadmap
CF-01	**Critical**	A production bastion host accepts SSH from the entire internet	5.3; 5.2; 5.7; 5.1.1	IT Operations Manager	17 Oct 2026 (rule) · 30 Nov 2026 (bastion replaced)	S	AWS-01; AWS-08
CF-02	**Critical**	A contractor login from the March 2025 incident is still live, with no MFA	1.9; 1.10; 1.11; 1.13; 1.14	IT Operations Manager	17 Oct 2026	S	AWS-01; AWS-12
CF-03	**Critical**	A former consultant's cloud account can still read a 2024 customer database export	2.1.4 (bucket); 2.1.3; 1.19; 3.8; 3.9	Chief Technology Officer	17 Oct 2026 (access) · 20 Oct 2026 (decision) · 23 Oct 2026 (deletion)	S	AWS-01; AWS-02; AWS-04
CF-04	**High**	Account-wide S3 Block Public Access is switched off	2.1.4 (account)	Chief Technology Officer	30 Nov 2026	M	AWS-05
CF-05	**High**	Customer data is encrypted, but with keys Cypher does not manage	3.5; 3.6 (N/A); 5.1.1; 2.2.1 (pass)	Chief Technology Officer	31 Dec 2026	M	AWS-11
CF-06	**High**	The cloud's diary covers one region of one account, and it is not sealed	3.1; 3.2; 3.4; 3.8; 3.9	IT Operations Manager	30 Nov 2026	S (trail) · M (log archive)	AWS-06
CF-07	**High**	Nobody is told when something bad happens in the cloud	4.1-4.15; 4.16; 3.3	IT Operations Manager	31 Jan 2027	M	AWS-10
CF-08	**High**	The root user is used for billing and protected by a phone app, not a hardware key	1.5; 1.6; 4.3 (1.3 and 1.4 pass)	Chief Technology Officer	30 Nov 2026	S	AWS-07
CF-09	**High**	Engineers hold full administrator rights, with phishable MFA, on accounts nobody manages centrally	1.15; 1.14; 1.20; 1.19 (+ CGI-POL-002 s4.3.3 inspection)	IT Operations Manager	31 Jan 2027	M	AWS-12

ID	Severity	Finding	CIS	Owner	Due	Effort	Roadmap
CF-10	**Medium**	Deployments use a 412-day-old access key	1.13	Chief Technology Officer	31 Dec 2026	S	AWS-13
CF-11	**Medium**	The cloud password rule is weaker than Cypher's own policy	1.7; 1.8	IT Operations Manager	23 Oct 2026	S	AWS-03
CF-12	**Low**	Network traffic goes unrecorded and default network rules are untouched	3.7; 5.5	IT Operations Manager	31 Mar 2027	S	AWS-16
CF-13	**Low**	S3 accepts plain-HTTP requests and has no delete protection	2.1.1; 2.1.2	Chief Technology Officer	31 Mar 2027	S	AWS-16
CF-14	**Medium**	CloudCo has no security contact for Cypher and no support role	1.2; 1.16	IT Operations Manager	23 Oct 2026	S	AWS-03
CF-15	**Medium**	Database minor upgrades depend on someone remembering	2.2.2	Chief Technology Officer	31 Dec 2026	S	AWS-14

15 findings: 3 Critical · 6 High · 4 Medium · 2 Low. The three Criticals have one root cause: **temporary access that was never revoked.**

Critical	Opened	Open for
CF-01 · SSH rule	14 Mar 2025, incident	581 days
CF-02 · contractor login	14 Mar 2025, same incident	581 days
CF-03 · consultant's grant	11 Jun 2024, database migration	857 days

Each was undetected because nothing watches for change (CF-07).

6.3 Findings in full

CF-01 · Critical · A production bastion host accepts SSH from the entire internet

CIS	5.3; 5.2; 5.7; 5.1.1
What exists	sg-bastion allows TCP 22 from 0.0.0.0/0 on cgi-prod-bastion-01, a public host whose instance role can read customer exports. The rule was added by ext-ops-contractor on 14 Mar 2025 during a database incident, with no change ticket, and never removed. The default network ACL allows the same traffic, the host accepts IMDSv1 and its volume is unencrypted.
Root cause	Temporary incident access never reverted; no configuration baseline (CG-03); no change record for cloud changes; no alert on security group changes (4.10).
Remediation	Remove the 0.0.0.0/0 rule today. Replace the bastion with Session Manager, which needs no inbound port. Require IMDSv2. Add a Config rule for unrestricted SSH with an alert.
Effort · Owner · Due	S · IT Operations Manager · 17 Oct 2026 (rule) · 30 Nov 2026 (bastion replaced)
Risk · CUEC · Roadmap	R-005; R-002 · - · AWS-01; AWS-08

CF-02 · Critical · A contractor login from the March 2025 incident is still live, with no MFA

CIS	1.9; 1.10; 1.11; 1.13; 1.14

What exists	ext-ops-contractor has a console password with no MFA, full administrator rights through a directly attached policy, and an access key created on day one and never used. Last sign-in 02 Apr 2025 (562 days). The engagement ended in April 2025. No leaver ticket exists.
Root cause	Contractors sit outside the HR-driven leaver process (the OFI-06 population gap); CloudCo users are not federated with OfficeCo (1.20), so nothing cascades; the monthly orphaned-account reconciliation (CGI-POL-003 s4.7.3) has never run for CloudCo.
Remediation	Disable the console password and delete the key today. Review CloudTrail for any activity since 02 Apr 2025 (eu-central-1 only - see limitation L-02). Root cause is fixed by CF-09.
Effort · Owner · Due	S · IT Operations Manager · 17 Oct 2026
Risk · CUEC · Roadmap	R-005; R-003; VR-008 · CUEC 3 · AWS-01; AWS-12

CF-03 · Critical · A former consultant's cloud account can still read a 2024 customer database export

CIS

Field	Value
	CIS
	2.1.4 (bucket); 2.1.3; 1.19; 3.8; 3.9

What exists

Field	Value
	What exists
	cgi-data-migration-2024 holds a full customer database export from the June 2024 migration (3 objects, Restricted under CGI-POL-004 s4.1.3). Bucket-level Block Public Access was switched off on 11 Jun 2024 and the bucket policy grants read and list to the migration consultant's CloudCo account. No data processing agreement is on file and the consultant is not in the CGI-TPR-001 inventory, because the engagement falls outside its 12-month finance lookback. S3 read events are not logged, so nobody can tell whether the export was read after the engagement ended.

Root cause

Field	Value
	Root cause
	One-off project data never disposed of (CGI-POL-004 s4.2 retention never executed - OFI-05); no external-access analyzer; no data discovery; vendor discovery did not include access-based sources.

Remediation

Field	Value
	Remediation
	Remove the cross-account statement today. The CTO records a breach-assessment decision under CGI-POL-005 s5.6.3, counting from awareness on 15 Oct 2026. Preserve the evidence, then delete the export under the CGI-POL-004 disposal rule with a deletion record. Obtain written confirmation that the consultant holds no copies. Enable IAM Access Analyzer everywhere. Record the consultant in CGI-TPR-001 as a terminated relationship.

Effort · Owner · Due

Field	Value
	Effort · Owner · Due
	S · Chief Technology Officer · 17 Oct 2026 (access) · 20 Oct 2026 (decision) · 23 Oct 2026 (deletion)

Risk · CUEC · Roadmap

Field	Value
	Risk · CUEC · Roadmap
	R-005; VR-001; VR-004 · CUEC 4 · AWS-01; AWS-02; AWS-04

CF-04 · High · Account-wide S3 Block Public Access is switched off

CIS	2.1.4 (account)
What exists	All four account-level settings have been false since 22 Feb 2024, when they were switched off to publish website assets from cgi-www-assets. Bucket-level settings protect 3 of 5 buckets, but nothing stops a new bucket or an edited policy from going public, and no SCP protects the setting. No customer data is public today: manual inspection of the one public bucket found 1,412 web assets only.
Root cause	The account-wide guardrail was removed to serve one public use case instead of putting the public assets behind a content delivery network.
Remediation	Serve cgi-www-assets through CloudFront with Origin Access Control. Turn on all four account-level settings. Add an SCP denying changes to Block Public Access except through a break-glass role. Add Config rules for account-level and bucket-level public access.
Effort · Owner · Due	M · Chief Technology Officer · 30 Nov 2026
Risk · CUEC · Roadmap	R-005 · - · AWS-05

CF-05 · High · Customer data is encrypted, but with keys Cypher does not manage

CIS

Field	Value
	CIS
	3.5; 3.6 (N/A); 5.1.1; 2.2.1 (pass)

What exists

Field	Value
	What exists
	cgi-prod-exports and cgi-prod-app-attachments use SSE-S3, the default. No customer-managed KMS key exists. The trail logs are SSE-S3 and EBS encryption by default is off. SSE-S3 is real encryption, but S3 decrypts an object for anyone the bucket policy allows, including everyone if the bucket goes public. It gives no protection against R-005's threat. SSE-KMS with a customer-managed key adds a second permission (kms:Decrypt) that an anonymous or foreign account does not hold.

Root cause

Field	Value
	Root cause
	No cryptography standard (A.8.24 Not started; ISO-11); CloudCo CUEC 4 never accepted.

Remediation

Field	Value
	Remediation
	Create customer-managed keys for exports, attachments and logs, with key policies limited to the application roles. Enable rotation. Switch default bucket encryption to SSE-KMS with bucket keys and re-encrypt existing objects. Turn on EBS encryption by default.

Effort · Owner · Due

Field	Value
	Effort · Owner · Due
	M · Chief Technology Officer · 31 Dec 2026

Risk · CUEC · Roadmap

Field	Value
	Risk · CUEC · Roadmap
	R-005; VR-004 · CUEC 4 · AWS-11

CF-06 · High · The cloud's diary covers one region of one account, and it is not sealed

CIS	3.1; 3.2; 3.4; 3.8; 3.9
What exists	One single-region trail (eu-central-1, production, since May 2023). Nothing is recorded in the management or staging accounts, in us-east-1 where the backups are copied, or in any other region. Log file validation is off, the trail bucket has no access logging, and no S3 data events are captured.
Root cause	Trail created at account setup and never revisited; REC-07 not started.
Remediation	One organisation trail from the management account covering all regions: management events plus S3 data events for Restricted buckets, validation on, SSE-KMS, delivered to a dedicated log-archive account with access logging and Object Lock.
Effort · Owner · Due	S (trail) · M (log archive) · IT Operations Manager · 30 Nov 2026
Risk · CUEC · Roadmap	R-005; R-003 · CUEC 1 · AWS-06

CF-07 · High · Nobody is told when something bad happens in the cloud

CIS	4.1-4.15; 4.16; 3.3
What exists	All 15 monitoring recommendations fail. Zero metric filters, rules, alarms or subscribers exist, because CloudTrail is not delivered to any log platform. AWS Config and Security Hub run only in production eu-central-1 and us-east-1, switched on 05 Oct 2026 for this review, and their findings go to nobody. GuardDuty is off.
Root cause	No monitoring owner and no alert-handling procedure (A.8.16 Not started; OFI-03).
Remediation	Enable Config, Security Hub and GuardDuty in every account and region with a delegated administrator. Create EventBridge rules for the 4.1-4.15 events, routed through SNS to the ChatCo security channel and email. Write an alert runbook that maps alerts to the CGI-POL-005 severity levels. Keep 90 days of handled-alert records.
Effort · Owner · Due	M · IT Operations Manager · 31 Jan 2027
Risk · CUEC · Roadmap	R-005; R-003; R-001 · CUEC 1 · AWS-10

CF-08 · High · The root user is used for billing and protected by a phone app, not a hardware key

CIS	1.5; 1.6; 4.3 (1.3 and 1.4 pass)
What exists	All three root users have authenticator-app MFA and no access keys. CGI-POL-002 s4.4.3 requires a hardware device; none is registered. The management-account root user signed in 4 times in 90 days for invoices and a card change, with no alert and no record, and its credentials are not sealed.
Root cause	Billing was never delegated to IAM; there is no root runbook.
Remediation	Register two FIDO hardware keys per root user. Turn on IAM access to Billing and give Finance a billing role. Alert the CTO and CEO on any root sign-in (4.3). Seal the credentials and document each use. Consider centralised root access management to remove root credentials from production and staging. Until the keys are installed, operate proposed exception EXC-004.

Effort · Owner · Due	S · Chief Technology Officer · 30 Nov 2026
Risk · CUEC · Roadmap	R-005 · CUEC 2 · AWS-07

CF-09 · High · Engineers hold full administrator rights, with phishable MFA, on accounts nobody manages centrally

CIS	1.15; 1.14; 1.20; 1.19 (+ CGI-POL-002 s4.3.3 inspection)
What exists	cgi-ops-fullaccess (Action '', *Resource* '') is attached to Engineering-Admins (4 users) and to the contractor. No separate administrative accounts exist (CGI-POL-002 s4.4.1). Users are created per account, not federated with OfficeCo. All 7 MFA devices are authenticator apps, contrary to s4.3.3. No access analyzer runs and no quarterly privileged access review has ever been performed (OFI-15).
Root cause	The start-up permission model was never revisited; CloudCo CUEC 3 was never accepted.
Remediation	IAM Identity Center federated with OfficeCo. Permission sets: read-only by default, time-bound elevation to admin. FIDO2 keys for administrators. Delete IAM users. Access analyzers for external and unused access. First quarterly review under REC-02.
Effort · Owner · Due	M · IT Operations Manager · 31 Jan 2027
Risk · CUEC · Roadmap	R-005; R-003; R-001 · CUEC 3 · AWS-12

CF-10 · Medium · Deployments use a 412-day-old access key

CIS	1.13
What exists	codeco-deploy uses a long-lived access key, never rotated, stored as a CodeCo repository secret. It can update ECS services and write to cgi-www-assets.
Root cause	The deployment pipeline was set up before OpenID Connect federation was considered; no rule covers machine credentials.
Remediation	Federate CodeCo's CI service to an IAM role with OpenID Connect and short-lived credentials, scoped to the deploy actions. Delete the key.
Effort · Owner · Due	S · Chief Technology Officer · 31 Dec 2026
Risk · CUEC · Roadmap	R-005; R-004 · CUEC 3 · AWS-13

CF-11 · Medium · The cloud password rule is weaker than Cypher's own policy

CIS	1.7; 1.8
What exists	Minimum length 8 and no reuse prevention in all three accounts. CGI-POL-002 requires 14, or 16 for privileged accounts, and every CloudCo console user is privileged.
Root cause	The CloudCo default was never changed after the policy pack was approved.
Remediation	Set minimum length to 16 and reuse prevention to 24 today. The rule falls away once access is federated (CF-09).
Effort · Owner · Due	S · IT Operations Manager · 23 Oct 2026
Risk · CUEC · Roadmap	R-001; R-005 · - · AWS-03

CF-12 · Low · Network traffic goes unrecorded and default network rules are untouched

CIS	3.7; 5.5
What exists	No VPC flow logs. Default security groups in the production VPC and every default VPC still allow internal and outbound traffic.

Root cause	Defaults accepted at account creation; no network baseline (A.8.20 Not started).
Remediation	Flow logs (rejected traffic at minimum) to the log archive. Strip the default security group rules and delete unused default VPCs.
Effort · Owner · Due	S · IT Operations Manager · 31 Mar 2027
Risk · CUEC · Roadmap	R-005; R-002 · - · AWS-16

CF-13 · Low · S3 accepts plain-HTTP requests and has no delete protection

CIS	2.1.1; 2.1.2
What exists	No bucket denies non-TLS requests. MFA Delete is off. Only the root user can switch it on, which conflicts with eliminating root use (RC-07).
Root cause	No storage baseline.
Remediation	Deny aws:SecureTransport = false on every bucket. Use S3 Object Lock in governance mode on the log archive and the Restricted buckets instead of MFA Delete, and record that as Cypher's deviation from 2.1.2.
Effort · Owner · Due	S · Chief Technology Officer · 31 Mar 2027
Risk · CUEC · Roadmap	R-005; R-002 · CUEC 4 · AWS-16

CF-14 · Medium · CloudCo has no security contact for Cypher and no support role

CIS	1.2; 1.16
What exists	No security alternate contact is registered in any account, so CloudCo's security notices reach an unmonitored billing mailbox. No role holds AWSSupportAccess, so opening a case during an incident needs admin or root.
Root cause	Account hygiene never reviewed.
Remediation	Register security@ as the security contact in all three accounts and create a support role.
Effort · Owner · Due	S · IT Operations Manager · 23 Oct 2026
Risk · CUEC · Roadmap	R-005; R-002 · - · AWS-03

CF-15 · Medium · Database minor upgrades depend on someone remembering

CIS	2.2.2
What exists	Auto minor version upgrade is off on cgi-prod-db. The last minor version was applied manually seven months ago.
Root cause	No platform patching rule: CGI-POL-001 s4.4.3 covers workstations; CGI-POL-008 is unwritten (CG-02).
Remediation	Enable auto minor version upgrade inside the maintenance window. Cover platform patching in CGI-POL-008 (REC-08).
Effort · Owner · Due	S · Chief Technology Officer · 31 Dec 2026
Risk · CUEC · Roadmap	R-004; R-002 · - · AWS-14

Part 7 — R-005 recalculated: CGI-RSK-001 v1.2

R-005 — Public S3 bucket through CloudCo misconfiguration. Inherent 20 (Likelihood 4 × Impact 5). Residual in v1.1: **12** (L3 × I4), High.

7.1 Why switched-off Block Public Access does not lower the score

The tempting move is: "Block Public Access is off, so control effectiveness drops, so the residual rises." **That would count the same weakness twice.** The v1.1 rationale already says, in writing, that there is *"no account-level S3 Block Public Access enforcement, no AWS Config rules, no drift alerting."* It gave those controls **zero** credit. A scan that confirms an assumption turns the assumption into evidence; it does not move the score.

What does move the score is evidence against the controls v1.1 *did* credit. NIST SP 800-30 scores residual risk against controls that are in place. A credit stands only while the evidence supports it.

7.2 Each v1.1 credit, tested

Element	Control credited in v1.1	Evidence	Decision
Likelihood	Quarterly privileged access review (CGI-POL-003 s4.7.1)	Not operating: zero reviews ever performed (CGI-IAU-001 WP-17, OFI-15).	Withdrawn
Likelihood	Role profiles keep most staff out of CloudCo production (CGI-POL-003 s4.2.1)	Operating in name only: every one of the 8 people with access holds full administrator rights, including a forgotten contractor (CF-02, CF-09).	Withdrawn
Likelihood	A ticket for every access change (CGI-POL-003 s4.1.5)	Not operating: no ticket for the 14 Mar 2025 SSH rule, the contractor account or the June 2024 bucket grant (CF-01, CF-02, CF-03; WP-22).	Withdrawn
Impact	Encryption at rest for Restricted data (CGI-POL-004 s4.2)	In place but ineffective against this threat: SSE-S3 serves objects decrypted to anyone the bucket policy allows (CF-05). A v1.1 design error, corrected here.	Withdrawn
Impact	Restricted data only on named approved systems (CGI-POL-004 s4.2)	Not operating: a full customer export sits in an unapproved bucket that a third party can read (CF-03); no asset inventory (OFI-18).	Withdrawn

All five credits are withdrawn. The controls that did pass (1.3, 1.4, 2.2.1, 2.2.3) protect other paths: the root user and the database. They do nothing about an administrator exposing an S3 export. Counting them would be like counting the seatbelt in a different car.

7.3 The arithmetic (CGI-RSK-001 §1 scales, unchanged)

	Likelihood	Impact	Score	Rating
Inherent	4	5	**20**	Critical
Residual v1.1	3	4	**12**	High
Residual v1.2	**4**	**5**	**20**	**Critical**

- **Likelihood 3 → 4.** CGI-RSK-001 §1.1 anchor 4: *"a known, unmitigated weakness exists at Cypher"*. There is no guardrail, no detection, and three misconfigurations by authorised people have already happened. **Not 5:** anchor 5 means *"already occurring"*, and no customer data is public today. Manual inspection of the one public bucket found web assets only (limitation: no data discovery has run).
- **Impact 4 → 5.** With SSE-S3, a public export is readable in plain text, so the worst credible outcome is the inherent one: Art. 33 and 34 notification at scale, enterprise sales lost.
- **v1.2 residual = 4 × 5 = 20.** Reduction from inherent: **0** (was 8).

7.4 The path back down

Step	By	What changes	L	I	Score	Rating
v1.1 (today's register)	15 Sep 2026	Credits for five preventive controls	3	4	12	High
v1.2 (this review)	16 Oct 2026	All five credits withdrawn on the evidence	4	5	20	Critical

Step	By	What changes	L	I	Score	Rating
After Phase 0-1	30 Nov 2026	AWS-01 to AWS-09: account-level Block Public Access protected by an SCP, SSH closed, contractor and consultant access removed	2	5	10	High
After AWS-11	31 Dec 2026	Customer-managed KMS keys on the Restricted buckets	2	4	8	Medium
After AWS-10	31 Jan 2027	Config, Security Hub, GuardDuty and alerts in every account and region, handled under a runbook	2	3	6	Medium
After AWS-15 and AWS-17	30 Jun 2027	Approved baseline standard and two clean quarterly assessments	1	3	3	Low

- **AWS-05 (Block Public Access protected by an SCP)** turns trust in people into a technical guardrail: **L 4 → 2**.
- **AWS-11 (customer-managed keys)** makes a leaked object unreadable to an outsider: **I 5 → 4**.
- **AWS-10 (detection)** means Cypher finds an exposure within hours, not a researcher: **I 4 → 3**.
- **TP-09's target of 6 is reached on 31 Jan 2027**, but only with AWS-11 and AWS-10 added (conflict RC-04).
- **TP-10's target of 4 is met at 3** after two clean quarterly assessments.

7.5 CGI-RSK-001 v1.2 — what changes in the register

Measure	v1.1	v1.2
Risks	14	14 (no new risk: every finding sits inside an existing risk's scenario)
Inherent total	213	213
Residual total	122	**130**
Aggregate reduction	42.7%	**39.0%**
Mean residual	8.71	**9.29**
Residual Critical · High	0 · 3	**1 · 2**
Original five risks (Project 02 headline)	92 → 44	**92 → 52**

No new risk is added. CF-01 to CF-15 all sit inside R-005's scenario (its asset list names S3, security groups and IAM), and R-005's treatments would prevent or detect them: TP-09's guardrails, plus TP-10's quarterly CIS baseline, which includes the external access analyzer (1.19) that flags a grant like CF-03 on day one. Under the Project 04 test, a risk is new only if the existing risk's controls would not have prevented it.

Governance consequence. Under CGI-RSK-001 §1.4 a Critical residual is *"not tolerable; requires immediate treatment and executive visibility"*. Only the CEO, with Board notification, could accept it, and review is quarterly and on any material change. Accepting a Critical that costs about USD 330 and staff time to fix would be indefensible, so R-005 is treated, not accepted. Phase 0 is that treatment.

Flagged, not re-scored. R-001 credits FIDO2 keys on privileged CloudCo accounts, and CF-09 shows authenticator-app codes instead. This review tested R-005's controls, not R-001's, so R-001 goes to the Q1 2027 register review (REC-10) rather than being re-scored on partial evidence.

Part 8 — Remediation roadmap and reconciliation

8.1 AWS-01 to AWS-18

ID	Phase	Action	Closes	Owner	Due	Est. cost (USD)	Reconciles with
AWS-01	Phase 0 - Contain	Remove SSH from 0.0.0.0/0; disable ext-ops-contractor and delete its key; remove the consultant's cross-account grant	CF-01; CF-02; CF-03	IT Operations Manager	17 Oct 2026	0	REC-11 (pulled forward - RC-01)

ID	Phase	Action	Closes	Owner	Due	Est. cost (USD)	Reconciles with
AWS-02	Phase 0 - Contain	Breach-assessment decision under CGI-POL-005 s5.6.3 for CF-03; review CloudTrail for contractor and consultant activity	CF-03; CF-02	Chief Technology Officer	20 Oct 2026	0	-
AWS-03	Phase 0 - Contain	Password policy 16 / reuse 24; security contacts; support role	CF-11; CF-14	IT Operations Manager	23 Oct 2026	0	-
AWS-04	Phase 0 - Contain	Preserve evidence, then delete the 2024 export under the CGI-POL-004 disposal rule; record the consultant as a terminated relationship in CGI-TPR-001	CF-03	Chief Technology Officer	23 Oct 2026	0	ISO-09 (records); REC-15
AWS-05	Phase 1 - Guardrails	Website assets behind CloudFront with Origin Access Control; account-level Block Public Access on; SCP protecting it	CF-04	Chief Technology Officer	30 Nov 2026	Within TP-09 estimate	TP-09 (part)
AWS-06	Phase 1 - Guardrails	Organisation trail: all accounts and regions, validation, access logging, S3 data events for Restricted buckets	CF-06	IT Operations Manager	30 Nov 2026	Within TP-09 estimate	REC-07 (part, pulled forward - RC-02)
AWS-07	Phase 1 - Guardrails	Root: hardware keys, billing delegated, root-use alert, sealed credentials; proposed exception EXC-004 until done	CF-08	Chief Technology Officer	30 Nov 2026	Hardware keys (planning estimate USD 330)	-
AWS-08	Phase 1 - Guardrails	Replace the bastion with Session Manager; require IMDSv2; EBS encryption by default	CF-01; CF-05	IT Operations Manager	30 Nov 2026	0	REC-18 (split - RC-03)
AWS-09	Phase 1 - Guardrails	Sign the CloudCo CUEC acceptance record: four CUECs, four owners, the AWS roadmap dates	CUEC 1-4	Chief Executive Officer	15 Dec 2026	0	ISO-02; VRA-2026-001 C1; SOC-01
AWS-10	Phase 2 - Detect and encrypt	Config, Security Hub and GuardDuty organisation-wide; EventBridge alerts for 4.1-4.15; alert runbook	CF-07	IT Operations Manager	31 Jan 2027	Within TP-09 estimate (USD 1,200 a year - validate)	TP-09 (detective part); REC-07; REC-11 (part)
AWS-11	Phase 2 - Detect and encrypt	Customer-managed KMS keys and SSE-KMS on Restricted buckets and the log archive; rotation on	CF-05	Chief Technology Officer	31 Dec 2026	Small (key charges)	ISO-11 (A.8.24 part, pulled forward - RC-05)
AWS-12	Phase 2 - Detect and encrypt	IAM Identity Center federated with OfficeCo; permission sets; FIDO2 for admins; delete IAM users; access analyzers	CF-09; CF-02	IT Operations Manager	31 Jan 2027	0	REC-02; REC-01
AWS-13	Phase 2 - Detect and encrypt	OpenID Connect deploy role for CodeCo; delete codeco-deploy key	CF-10	Chief Technology Officer	31 Dec 2026	0	REC-06
AWS-14	Phase 2 - Detect and encrypt	RDS auto minor version upgrade	CF-15	Chief Technology Officer	31 Dec 2026	0	REC-08
AWS-15	Phase 3 - Baseline	Approve the Cloud Configuration Baseline Standard (Cypher profile: Level 1 plus six named Level 2) with an exception route	All	Chief Technology Officer	28 Feb 2027	0	TP-10
AWS-16	Phase 3 - Baseline	Flow logs; default security groups emptied; unused default VPCs deleted; TLS-only bucket policies; Object Lock	CF-12; CF-13	IT Operations Manager	31 Mar 2027	Small (log storage)	REC-18

ID	Phase	Action	Closes	Owner	Due	Est. cost (USD)	Reconciles with
AWS-17	Phase 3 - Baseline	Quarterly re-assessment against v5.0.0, then re-baseline to the current CIS release	All	IT Operations Manager	30 Jun 2027	0	REC-11; TP-10
AWS-18	Phase 4 - Sustain	Capture the baseline as infrastructure as code with peer review	All	Chief Technology Officer	30 Sep 2027	0	REC-06; SOC-07

Cost. Phases 0 and 1 need no new spend beyond about USD 330 of hardware keys (planning estimate). Monitoring cost sits inside TP-09's existing USD 1,200 a year planning estimate, which must be validated against CloudCo's pricing before approval. Everything else is staff time.

8.2 Conflicts with earlier deliverables, stated and resolved

ID	Earlier deliverable says	The evidence says	Resolution
RC-01	REC-11 dates the CIS baseline to Q2 2027.	Three Critical findings cannot wait eight months.	Split REC-11: containment now (AWS-01 to AWS-04), baseline in Q2 2027 as planned (AWS-17).
RC-02	REC-07 dates CloudTrail work to Q1 2027; condition C1 falls due 15 Dec 2026.	CUEC 1 would be accepted with no trail behind it.	Trail and validation take about an hour: pulled forward to 30 Nov 2026 (AWS-06). Log archive and alerting stay in Q1 2027 (AWS-10).
RC-03	REC-18 dates network segmentation to Q4 2027.	CF-01 is a one-line rule change, not a segmentation project.	AWS-01 and AWS-08 close the exposure now; REC-18 keeps the segmentation documentation.
RC-04	TP-09 targets a residual of 6.	TP-09 alone reaches 10 (L2 x I5): it adds a guardrail and detection, but no key management.	TP-09's target of 6 now depends on AWS-11 (KMS) and AWS-10 (detection). Recorded in CGI-RSK-001 v1.2.
RC-05	ISO-11 schedules A.8.24 (cryptography) from Jan 2027.	R-005's impact credit depends on customer-managed keys.	AWS-11 pulls the Restricted-bucket part of A.8.24 forward to 31 Dec 2026; the rest of ISO-11 is unchanged.
RC-06	The CIS Level 1 profile excludes 1.5, 3.2, 3.3, 3.5, 3.6 and 4.16.	CGI-POL-002, the CloudCo CUECs and TP-09 / REC-11 require them.	The Cypher profile is Level 1 plus those six Level 2 items. Policy and contracts outrank the profile choice.
RC-07	CIS 2.1.2 (MFA Delete) can only be enabled by the root user.	CIS 1.6 says eliminate root use.	Use S3 Object Lock instead and record the deviation from 2.1.2 in the baseline standard.
RC-08	CGI-TPR-001 lists 17 suppliers, found from four sources including a 12-month finance lookback.	CF-03 found a 2024 consultant with live access to customer data.	Add 'access-based discovery' (external-access analyzer findings) as a fifth source. The count stays 17: the relationship ended in 2024 and is recorded as terminated.
RC-09	CGI-SOC-001 called the four CloudCo CUECs 'unaccepted'.	They are now evidenced as not performed: 0 of 4.	OFI-07 and the mirror in CGI-SOC-001 Part 3.4 cite CGI-AWS-001 as evidence. SOC-01's carve-out holds only once AWS-09 is signed.
RC-10	CGI-RSK-001 v1.1 scores R-005 residual 12, and R-001 credits FIDO2 keys for privileged CloudCo accounts.	The evidence supports neither credit.	R-005 is re-scored to 20 in v1.2. R-001 is flagged for the Q1 2027 register review rather than re-scored here, because this review tested R-005's control set, not R-001's.

8.3 What does not change

- **The ISO/IEC 27001 certificate target stays November 2027** (CGI-ISO-001). Every AWS action lands before Stage 1 in July 2027.
- **The SOC 2 path stays:** Type I as of 31 March 2028, Type II report around November 2028 (CGI-SOC-001). AWS-10 starts producing the alert records SOC-07's evidence capture needs.
- **REC-01 to REC-18, ISO-01 to ISO-17 and SOC-01 to SOC-14 keep their IDs and owners.** Four are pulled forward in part (RC-01, RC-02, RC-03, RC-05); none is deleted.

Part 9 — Effect on maturity, the SoA and SOC 2 readiness

9.1 CGI-GAP-001: the score does not move — 1.32 stays 1.32

Category	Before	After	Why	What would move it
PR.PS Platform Security	0	0	A review that finds the baseline absent measures the gap; it does not close it. No configuration standard exists, so nothing is established or applied.	2 when the baseline standard (AWS-15) is approved; 3 after two evidenced quarterly assessments (AWS-17).
PR.IR Technology Infrastructure Resilience	0	0	The network is now documented as exposed (CF-01, CF-12); documentation of a hole is not protection.	2 when a security-group and VPC baseline is approved and SSH is closed; 3 with review records.
DE.CM Continuous Monitoring	1	1	Config and Security Hub have run for 11 days in two regions of one account, routed to nobody. A prerequisite is not a score.	2 when monitoring is organisation-wide with a named owner and runbook (AWS-10); 3 after 90 days of handled-alert records.
PR.AA Identity Management, Authentication and Access Control	2	2	Root MFA (1.4) and no root keys (1.3) are evidenced, but phishable MFA on admins and a live contractor login contradict the policy. A 2 already means approved but unevidenced.	3 when federation, FIDO2 for admins and the first quarterly review are evidenced (AWS-12, REC-02).
PR.DS Data Security	2	2	Encryption exists at the provider level only, and Restricted data was found outside approved systems. Consistent with 2, not 3.	3 when customer-managed keys protect the Restricted buckets and discovery has run (AWS-11, CF-03).
ID.AM Asset Management	1	1	This review listed accounts, regions, buckets and hosts. A cloud resource list is an input to REC-05, not an asset inventory.	2 when REC-05 delivers the inventory with owners and classification.
GV.SC Cybersecurity Supply Chain Risk Management	2	2	The CUECs are now evidenced as not performed, but the programme that found them is unchanged.	Unchanged by this project.

PR.PS and PR.IR stay at 0, and DE.CM stays at 1.

- A configuration review that finds the baseline absent measures the gap; it does not close it.
- Monitoring switched on eleven days ago in two regions, routed to nobody, is a prerequisite. A prerequisite is not a score.
- **The arithmetic:** the sum of the 22 Category scores is 29 before and 29 after, so 29 ÷ 22 = **1.32**.

9.2 CGI-ISO-001 Statement of Applicability

No control changes status, and readiness stays at 30.6%. What changes is the **Evidence held** column:

Control	Status (unchanged)	Evidence now held from CGI-AWS-001
A.5.23 Cloud services	Partial	CUEC close-out: 0 of 4 performed; C1 route defined (AWS-09)
A.8.2 Privileged access rights	Partial	Root MFA virtual on 3 of 3 accounts; *:* policy on 5 identities
A.8.5 Secure authentication	Partial	7 of 8 console users with MFA, all authenticator-app codes
A.8.9 Configuration management	Not started	First assessment against CIS v5.0.0: profile score 24.4%
A.8.15 Logging	Partial	One single-region trail; validation off
A.8.16 Monitoring activities	Not started	0 of 15 monitoring recommendations met
A.8.20 Networks security	Not started	SSH open to 0.0.0.0/0 on the bastion
A.8.24 Use of cryptography	Not started	Provider-managed keys only; no customer-managed key

9.3 CGI-SOC-001 readiness

Type I 53.9% and Type II 36.0% are unchanged: no criterion's mapped control moved. OFI-03 and OFI-07 are now evidenced by CGI-AWS-001, and PBC-31 (the CloudTrail configuration request) is answered, showing failure. **SG-8, the gate that says a carve-out needs vendor controls, can only pass once AWS-09 is signed.**

Part 10 — One-page executive summary

To: Jerry Gold, Chief Executive Officer · **From:** O.S · **Date:** 16 October 2026 · **Subject:** Is our cloud set up safely?

In three sentences.

1. Our cloud passes 12 of the 60 industry-benchmark checks that apply to it (20%), and three failures are open doors today: an administrator port reachable from the whole internet, a former contractor's login with no second factor, and a former consultant's account that can still read a 2024 copy of our customer database.
2. Because the safeguards our risk register was counting on turn out not to be running, our top cloud risk rises from High to **Critical (12 → 20)**, which under our own rules needs your personal ownership and notice to the Board. Nothing is known to have leaked, but read logging was off, so for the consultant's access we cannot prove it.
3. **Decision: NO-GO** on telling enterprise buyers our cloud follows the CIS benchmark; **GO** on a seven-day containment sprint (no new spend) and about USD 330 for hardware keys, which brings the risk back to High by 30 November and to our target of 6 by 31 January 2027.

What we need from you

#	Decision	By
1	Approve the Phase 0 containment sprint (AWS-01 to AWS-04)	Today
2	Receive the CTO's breach-assessment decision on the consultant's access (CF-03)	20 Oct 2026
3	Approve CGI-RSK-001 v1.2 (R-005 Critical) and notify the Board	23 Oct 2026
4	Approve proposed exception EXC-004: virtual root MFA plus a root-login alert, until hardware keys arrive, expiring 30 Nov 2026	23 Oct 2026
5	Sign the CloudCo CUEC acceptance record (condition C1)	15 Dec 2026

What does not change: the ISO 27001 target (November 2027), the SOC 2 path (report around November 2028) and the maturity score (1.32). This is cheap to fix. It is expensive only if a customer or a researcher finds it first.

Appendix A — Verification, assumptions and limitations

A.1 Verification performed in code, not by eye

Check	Result
63 recommendations, IDs, titles, levels and Automated/Manual status checked against the CIS v5.0.0 document and an independent open-source compliance mapping	Match
Security Hub control mapping checked against AWS's published v5.0.0 mapping table	37 recommendations mapped (40 controls; 2.1.4, 2.2.4 and 2.3.1 map to two each)
Every FAIL cites a finding; every finding is cited by at least one recommendation	Pass (48 FAILs, 15 findings)
Scores recomputed in code and as workbook formulas	20.0% · 27.5% · 24.4%
Register totals recomputed from all 14 risks	213 inherent · 122 → 130 residual
CSF maturity recomputed	29 ÷ 22 = 1.32, unchanged

Check	Result
Workbook recalculated in LibreOffice	0 formula errors; 22 of 22 issue-checklist rows PASS
Simulated supplier names only	No real vendor name in any public file

A.2 Assumptions

ID	Assumption
AWS-A01	The organisation has three accounts (management, production, staging); production holds all customer data.
AWS-A02	Console access to CloudCo is by IAM users; OfficeCo federation covers SaaS applications only.
AWS-A03	The 2024 migration consultant was engaged under a statement of work; no data processing agreement has been located.
AWS-A04	Day counts run to the review date, 16 October 2026.

A.3 Limitations

ID	Limitation	Effect
L-01	Simulated environment	No real account was scanned. Every configuration result is a labelled scenario built to be consistent with Projects 1-6. The method, commands and mappings are the ones a real review would use.
L-02	Log coverage	The only trail covers production eu-central-1. Activity elsewhere before this review cannot be reconstructed, so the CF-02 and CF-03 activity reviews are partial by design.
L-03	Staging excluded	Staging resources were not assessed. The next quarterly assessment (AWS-17) includes them.
L-04	Point in time	Results describe 12-16 October 2026. Without organisation-wide Config, nothing evidences the months before or after (configuration drift).
L-05	Manual checks by inquiry	Manual recommendations rest on inspection and inquiry of the CTO and IT Operations Manager. Inquiry alone is weak evidence and is labelled as such.
L-06	Benchmark version	v5.0.0 is used because it is the version Security Hub CSPM automates. Newer CIS releases exist; re-baselining is on the roadmap (AWS-17).
L-07	Not engineering	This is a compliance and configuration review against a published benchmark, not cloud engineering. Remediation steps name the control to implement; an engineer designs and tests the change.

Appendix B — Glossary

Term	Meaning
BPA	S3 Block Public Access
CIS	Center for Internet Security
CloudCo	Cypher's simulated cloud provider (CGI-VEN-001), modelled on AWS
CMK	Customer-managed key (KMS)
CSPM	Cloud Security Posture Management
CUEC	Complementary user entity control: a control a supplier's report assumes the customer performs
Drift	A setting changing from its approved value over time
IaC	Infrastructure as code
IAM	Identity and Access Management
IMDSv2	Instance Metadata Service version 2: session-protected credential delivery to a server
KMS	Key Management Service
MFA	Multi-factor authentication. **FIDO2**: the phishing-resistant hardware-key or passkey standard
NACL	Network access control list (subnet firewall)

Term	Meaning
OAC	Origin Access Control: lets a content delivery network read a private bucket
OIDC	OpenID Connect: lets a CI service obtain short-lived cloud credentials without stored keys
SCP	Service control policy: an organisation-wide guardrail
SSE-S3 / SSE-KMS	S3 encryption with provider-managed keys / with KMS keys the customer controls
SSH	Secure Shell, remote administration on port 22
TSC	SOC 2 Trust Services Criteria
VPC	Virtual Private Cloud

Source documents

- Center for Internet Security, *CIS Amazon Web Services Foundations Benchmark v5.0.0* — cisecurity.org/benchmark/amazon_web_services
- AWS, *CIS AWS Foundations Benchmark in Security Hub CSPM* (control mapping by version) — docs.aws.amazon.com
- AWS, *Shared Responsibility Model* — aws.amazon.com/compliance/shared-responsibility-model
- NIST, *Cybersecurity Framework 2.0* (CSWP 29) — nist.gov/cyberframework
- NIST, *SP 800-30 Rev. 1, Guide for Conducting Risk Assessments* — csrc.nist.gov
- Portfolio inputs: CGI-POL-001 to -005 · CGI-RSK-001 v1.1 · CGI-GAP-001 · CGI-TPR-001 · CGI-ISO-001 · CGI-SOC-001 / CGI-IAU-001

Prepared by O.S · CGI-AWS-001 v1.0 · 16 October 2026